

TOLVEY | Public Commerce & Private Operations

TOLVEY

Isi Dokumen

1. Arti own shop yang resmi
2. Trust surfaces dan topologi
3. Public commerce layer
4. Private operations/control plane
5. Distribution/demand: internal control, public outputs
6. Identity, authorization dan action safety
7. Canonical services and orchestration
8. Stack/provider selection and decision gates
9. Production-grade controls and enterprise evolution
10. Monitoring, finance truth and failure isolation
11. Indonesian business/legal launch register
12. Current gaps and build sequence
13. Acceptance tests for layer separation (target, not executed)
14. Official-source register — reviewed 2026-10-01

TOLVEY — Public Commerce & Private Operations Architecture

Versi 1.0 — 2026-10-01. Status: **spesifikasi target dan rekomendasi**, bukan implementasi baru, sertifikasi enterprise, atau commerce production yang sudah aktif.

Baseline dokumentasi: bed6200ceb3fda039468b3876888537a253342a4. Last deployed code: d73a4dfba04c8207f2b5f440e0052840cefdcf3d. Repo: <https://github.com/Sparkmind-obp-off/Tolvey>, branch main, workspace /home/user/webapp.

Ringkasan keputusan

TOLVEY dibangun sebagai **platform commerce publik milik TOLVEY, didukung control plane operasi privat**, bukan satu dashboard internal yang diberi tombol beli, dan bukan marketplace multi-vendor V1.

Pisahkan pengalaman dan privilege, **jangan menggandakan product/order truth**. Pilihan awal: modular Hono/TypeScript pada Cloudflare Pages, D1 canonical, private R2 untuk aset, Duitku POP sebagai adapter. Tambahkan identity operator, customer ownership/recovery, transactional email dan monitoring sesuai gate; bukan mengganti semuanya dengan framework/provider baru.

Arsitektur memiliki dua lapisan bisnis besar dengan beberapa trust surface:

- **Public commerce layer:** public storefront + protected customer experience + machine-facing provider ingress.
- **Private/internal layer:** operations console + domain commands + distribution/demand control + monitoring/reconciliation + future durable workers.

Public-facing tidak sama dengan anonymous access. Customer area adalah pengalaman publik untuk pelanggan, tetapi records/order/download tetap privat per pelanggan. Provider callback terbuka secara jaringan namun hanya boleh mengubah truth setelah autentikasi provider dan validasi domain.

Tiga engine tetap **Own Commerce, Distribution, Brand/Demand**. Pemisahan public/private adalah dimensi akses, bukan pengganti tiga engine atau offering tiers free/digital/services. Money Kit tetap hipotesis. Strategi: **ONE PRODUCT, MANY DOORS**.

1. Arti own shop yang resmi

Ada tiga jenis kesiapan yang perlu dibedakan:

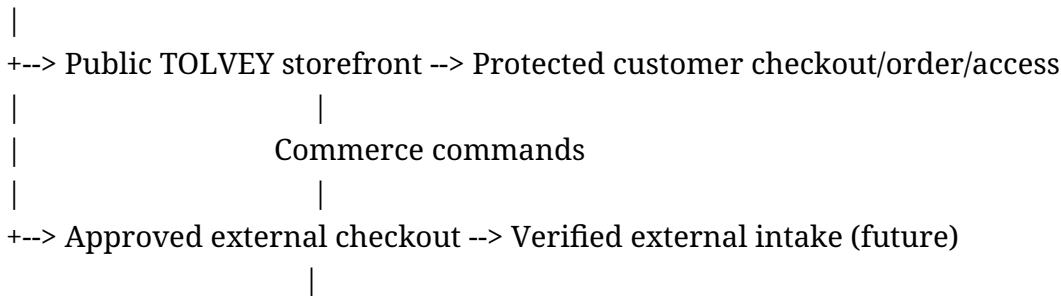
1. **Identitas owned commerce:** domain yang dikendalikan pemilik, identitas penjual/support yang benar, produk/terms yang jujur, checkout yang konsisten, customer receipt/status dan delivery.
2. **Production engineering:** authorization, money integrity, private delivery, kegagalan/retry, operational visibility, monitoring, release/recovery dan environment separation yang terbukti.
3. **Legal/business readiness Indonesia:** pemilik menentukan identitas/bentuk usaha, perizinan yang relevan, pajak, PSE/PMSE, consumer obligations dan PDP dengan bukti/proses yang sesuai. Desain software bukan surat izin atau penilaian hukum final.

Target tolvey.biz.id belum dikonfigurasi. Tidak ada registrasi PSE/perizinan/sertifikasi compliance yang diverifikasi dalam sesi ini. Public storefront TOLVEY **tidak berarti PSE Lingkup Publik dalam terminologi hukum**; platform usaha yang dapat diakses masyarakat dapat termasuk PSE Lingkup Privat. Jangan menyamakan public UI dengan klasifikasi lembaga publik [S8].

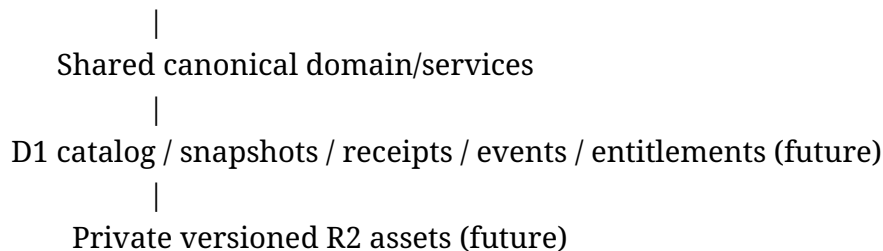
2. Trust surfaces dan topologi

Model logis

Traffic: social / personal brand / search / approved ads / external listings



Operator --> Private Ops (verified identity + permissions)



Duitku callback --> Provider-authenticated ingress --> Canonical transition

Side effects --> Durable receipt/outbox (when implemented) --> email / worker

Telemetry --> Restricted operations signals; never financial source of truth

Host/path strategy — target, bukan DNS/routes live

Surface	Target contoh	Akses dan tujuan
Storefront	tolvey.biz.id, /products, /services, /help, /policies	Anonymous curated content dan active catalog; endpoint names perlu finalisasi saat build
Customer	same origin /checkout, /orders, /access	Session/ownership-protected; no general admin rights
Internal awal	/ops dan API ops namespace pada deployment yang sama	Cloudflare Access BYOK + verified identity + app permissions; fail closed pada semua origin
Internal terpisah kelak	ops.tolvey.biz.id	Optional isolation saat kompleksitas/team membenarkan; bukan proyek baru wajib sekarang
Provider ingress	existing /api/provider/duitku-pop/callback	Tidak diberi operator login/Turnstile; tetap provider signature/context verification; production masih disabled
Assets	private R2 binding, bukan public download bucket	Stream melalui authorized entitlement; public preview terpisah
External channel links	Destination registry yang di-review	Allowed origin/listing; bukan arbitrary URL redirect

Mulai **satu deployment modular dengan namespace terpisah**, paling hemat integrasi. Itu pemisahan logis, bukan blast-radius isolation penuh: satu kompromi runtime dengan D1 binding tetap berisiko luas. Jika ops dipisah deployment, public

Pages project existing tetap canonical; internal Worker adalah komponen beralasan, bukan random replacement project. Setiap komponen baru, domain, binding dan deploy perlu authorization tersendiri.

Tolak unknown Host untuk protected surfaces, audit Pages default/immutable/preview origins dan path normalization. UI tersembunyi/noindex bukan security. Direct pages.dev tidak boleh menjadi bypass ops/customer auth. Jangan hanya melindungi ops subdomain sementara API yang sama masih anonim di domain publik. Customer cookie host-only, Secure/HttpOnly/SameSite; jangan share cookie ke seluruh subdomain. Credential di URL/query dilarang.

3. Public commerce layer

Minimum customer-facing product

Kemampuan	Minimum launch requirement	Deferred
Brand home/shop	Identitas TOLVEY, manfaat, katalog active dan CTA jelas	Banyak layout/campaign page tanpa offer
Product detail	Buyer/job, contents, preview, format/compatibility, pinned version, license, authoritative Offer price dan limitations	Reviews hanya jika genuine; bundles setelah grant rules
Services	Capability, scope boundaries, inquiry/support path	Instant purchase untuk bespoke scope yang belum pasti
Checkout	One offer/order, quantity 1, canonical IDR, minimum contact/policy acceptance, ownership, stable idempotency	Cart, coupons, subscription/affiliate engine
Payment	Server initiation/reservation, trusted provider redirect, verified callback/status; no browser-paid flag	Popup/custom method UI bukan gate
Order/status	Pending/confirmed/delivery issue/expired states untuk pemilik order	Public UUID lookup atau client status override
Access/delivery	Payment-gated entitlement ke immutable version, private stream, safe retry/support	Customer library lintas perangkat hanya setelah recovery/identity siap
Help/trust	Real seller/support contact, terms/license/refund/cancellation/privacy, delivery promise sesuai kemampuan	Fake badges, testimonials atau generic legal templates dianggap approval
Receipt/communication	Safe purchase summary/status; email bila menjanjikan recovery/notification	Delivered email bukan payment/delivery proof
Discovery/SEO	Canonical URLs, published sitemap, honest structured data, titles/social previews, archive/404 behavior	SEO mass generation tanpa useful content
Performance/accessibility	Semantic SSR, mobile/keyboard/labels/focus/errors, small JS dan assets	Heavy SPA hanya demi dashboard-look

Search/filter catalog hanya bila cukup item; satu produk tidak membutuhkan search engine. Initial free product bisa memakai grant/download terpisah; tidak perlu fake payment Rp0. Structured data tidak boleh mengarang rating, stock, sold count atau sale price. Paid assets tidak pernah masuk /public/static.

Customer isolation

Guest-first scoped session cukup untuk first loop; tidak wajib membangun social login/member subscription. Server memverifikasi principal → owned order → action pada **setiap** read/initiate/download/recovery. Order UUID/email bukan credential. Customer recovery membutuhkan verified email flow atau assisted verification yang didokumentasikan dan disetujui; jangan menjanjikan magic link yang belum dibuat.

Proposal recovery token: random high-entropy, hashed persistence, one-time/expiry/purpose/order bound, issue/use/revoke audit, rate limiting dan non-enumerating response. Hindari secrets pada URL; bila recovery email perlu link token, gunakan deliberate one-time exchange flow dengan referrer/log suppression dan immediate clean redirect, bukan general credential query yang terus dipakai. Pilihan token transport final membutuhkan security review. Cookie mutation memiliki origin/CSRF checks; idempotency scope terikat principal, bukan single-service global key existing.

Public catalog caching bisa ditambahkan setelah invalidation/publication/version policy terbukti; checkout/status/access/ops **no-store**. Public page yang menampilkan catalog cache bukan price authority saat createCheckout. Tidak ada customer data pada cache/CDN HTML publik.

4. Private operations/control plane

Private layer mengelola operasi bisnis, tidak menjadi landing page pelanggan. Console adalah **UI di atas bounded commands dan safe read views**, bukan editor database bebas.

Modul	First useful scope	Data/aksi yang tidak boleh diekspos publik
Product/offer control	Draft, review, validate package, publish/unpublish, version/manifest	Private assets, drafts, publication audit
Commerce operations	Order list/detail, normalized payment/fulfillment, exceptions	Customer contact, provider receipts/references dan operational metadata
Fulfillment/support	Entitlement/access issue, verified recovery, retry dengan stable receipts	Cross-customer grants, operator manual file leak
Reconciliation/finance view	Ambiguous/late/missing callbacks, fees/refund/settlement evidence	Mark-paid tanpa verification, fabricated refund completion
Distribution desk	Channel admission, listing/version/offer mapping, approved links, manual evidence import	Seller credentials, channel-order exports, private costs
Demand/brand desk	Evidence, hypotheses, content briefs/calendar, creatives/campaign/source/destination, experiment results	Customer/lead PII, budgets, private strategy; no fake signal
Service operations	Qualified inquiry, scope/capacity, milestones, deliverables/acceptance	Client-confidential materials; no silent master product mutation
Reliability desk	Incidents, health/config-safe summary, pending job age, failure/alert/runbook	Secret values, raw callbacks/body/logs; no public diagnostics dump
Governance	Principals/permissions, audited changes, export policy, release/migration history	Infrastructure tokens, emergency access/recovery credentials

Launch first: narrow publication workflow + order/exceptions/support view. Demand/distribution desk mula-mula structured records + manual operations; tidak wajib membangun scheduler/content automation agar produk dapat dijual.

Data D1 yang diusulkan: operator principals/permissions, publication audit, session/contact/policy, asset manifests, entitlements, exception/support cases, channel/listing/external origins, campaign/demand experiments dan notification/outbox receipts **hanya saat capability membutuhkan**. Ini belum tabel implemented. Tidak perlu CRM lengkap, financial ledger lengkap atau project-management suite V1.

5. Distribution/demand: internal control, public outputs

Engine	Internal work	Public/output work
Own Commerce	Product/version/offer approval, operations, support	Official product/service pages, supported checkout and customer delivery
Distribution	Policy/account/fees review, listing mapping, import/reconcile	External listing, storefront link, external checkout/delivery yang diizinkan
Brand/Demand	Evidence/experiment, content plan, personal-brand relationship, attribution/spend review	Social posts, product demos, search content, approved ads/landing links

Menyimpan planning secara internal tidak membuat traffic/listings tersembunyi. Traffic masuk ke own shop atau eligible external checkout. Return/status/customer links berbeda dari campaign links: payment/order references tidak diselipkan sebagai UTM analytics.

Outbound traffic contract

- Default: approved direct links yang clearly labeled sebagai external purchase/support; tidak perlu redirect service untuk semua klik.
- Bila click-out tracking diperlukan, public route menerima opaque approved destination ID, bukan caller-supplied URL. Registry mencatat channel/listing/product/version, allowlisted HTTPS destination, owner dan policy review.
- Reject arbitrary next/redirect URL, localhost/private IP/userinfo/scheme/host mismatch dan disabled destination. No open redirect, no automatic attachment of email/order/session/token.
- Capture bounded source/campaign/destination fact sesuai privacy policy; record click ≠ external checkout/payment. Adblock/missing attribution tetap UNKNOWN.
- Jika registry/telemetry gagal, jangan mengganggu paid order/access. Hanya gunakan fallback destination yang already approved; tidak mengalihkan trafik ke channel acak.
- External sales intake future memakai unique (**channel, external_order_id**), verified evidence dan canonical mapping. Jangan membuat own-shop CheckoutSession atau Duitku invoice untuk external payment.
- Indonesia TikTok Shop saat ini tidak mendukung virtual products/services; TikTok content tetap demand channel bila aturan promosi/link mengizinkan (docs/32). No fake physical shipment/policy evasion.

Public marketing boleh mulai dengan produk/preview yang jujur dan CTA inquiry/unavailable. Paid CTA dan ads conversion claims menunggu purchase/delivery gates serta spend approval.

6. Identity, authorization dan action safety

Operator identity recommendation

Gunakan **Cloudflare Access pada owner-account BYOK** untuk boundary internal, dengan IdP yang bisa menegakkan MFA, explicit allowlist, short sessions dan recovery/offboarding. Ini rekomendasi, bukan Access configured atau account entitlement verified.

Backend tetap memverifikasi signed Cf-Access-Jwt-Assertion: fixed trusted issuer/JWKS URL, allowed algorithm, expected audience, signature, expiry dan identity → enabled principal/permissions. Jangan trust email header, decode-only JWT, request-defined issuer/JWKS, atau cookie presence. Cache public keys bounded; refresh rotation; invalid/unknown key/config deny. Existing diagnostic operator bearer tetap server-only diagnostic, bukan ops login [S1].

BYOK Access identity dan app record/action authorization adalah berbeda dari Genspark Hosted route-admission descriptor. Project ini tidak berpindah ke Hosted atau mengubah descriptor. Jika deployment path nanti berubah, route admission mengikuti mekanisme platform; jangan menirunya dengan frontend JavaScript.

Proposed permissions — deny by default

Principal	Allowed scope	Explicit denial
Anonymous	Published public catalog/help, approved external destinations	Draft/order/contact/asset/ops/diagnostics
Customer session	Own checkout/order/access/support	Other orders; publication; finance/ops
Product operator	Product drafts/package QA, submit review	Mark-paid/refund, other customer exports, infra tokens
Support operator	Minimum related order/contact, verified recovery/request refund	Bulk finance export, product prices, unrestricted grants
Commerce/finance reviewer	Reconcile verified payment/refund/settlement evidence	Arbitrary paid flag, unreviewed external invoice re-initiation
Growth operator	Approved listings/campaigns/aggregate evidence	Provider secrets/individual purchase access
Owner/release operator	Approved publication/permissions/release decisions	Bypassing provider evidence or unrecorded destructive SQL
Service principal / consumer	Named bounded job/command with scoped credentials	General operator/customer capability

Initial one founder can hold several permissions; audit records actual actor. Two-person review is optional until another authorized reviewer exists; never claim separation of duties when one person approves themselves. High-risk changes use explicit confirmation/reason/current revision, step-up identity when available, preview/dry-run and immutable receipt. Offboarding disables principal independent of still-valid JWT; cached sessions must not override revocation indefinitely.

Customer vs operator vs service auth are separate contexts. CSRF/origin controls still apply to cookie/browser commands behind Access. Machine callback never requires customer/operator cookie or human CAPTCHA. Provider signature/context/state validation and bounded abuse controls remain mandatory.

7. Canonical services and orchestration

Initial architecture remains **modular application**: public/customer/ops handlers call the same narrow domain services. Domain layer owns publication and transaction rules; D1 atomic batch/CAS/immutable receipt preserves truth. No browser direct D1/R2/provider-secret access, no arbitrary state patch.

Potential module boundaries: catalog/publication, customer session, checkout/payment gateway, fulfillment/access, support/exceptions, external intake, growth records and reporting. Share reviewed domain contracts; not an independent product/payment model per UI.

If internal UI becomes a separate Worker, use a verified scoped service boundary to canonical commands. A service binding removes public Internet ingress need but is not a substitute for caller/action authorization. Avoid independent raw table writes by separate public/ops applications. D1 bindings are not fine-grained row-role credentials; logical permissions in one runtime do not provide database-level blast-radius isolation [S2].

Durable work without premature automation

- Initially: synchronous canonical commit + operator-visible exception + explicit reconcile action is enough for low volume. No fire-and-forget email/payment side effect.
- When reliable email/retries become necessary: persist durable outbox intent **in the same canonical batch** as triggering event; stable event/job ID, command version, minimal reference, status/attempt/time. Job claims bounded lease/CAS; actual send/outcome uses durable receipt. No raw customer PII/secrets in queue payload.
- An explicitly operated drain can start first; if promised timing cannot rely on manual drain, a scheduled/queue worker becomes a release dependency, not endlessly deferred.
- With Cloudflare Queues, delivery is at least once; dedup, bounded retry/backoff, DLQ, replay controls and monitoring required. Pages can produce messages but needs separate consumer Worker [S2/S3]. No queue exactly-once claim.
- Automatic retries must **not** apply to ambiguous RESERVED invoice creation. Provider reconciliation precedes a reviewed recovery action. Retrying notification send is not permission to create another invoice.
- Cloudflare Workflows is a later candidate for genuinely durable multi-step/human approvals, not needed just to display a dashboard. Workflows retries do not undo external side effects; command/receipt/idempotency rules still apply [S4].

Queue/outbox/Workflows/scheduler are target options, not current resources. BYOK supports a reviewed dedicated Worker deployment; existing Pages config cannot blindly host a queue consumer or scheduled handler. No platform Hosted binding compatibility presumed and no Node daemon at runtime.

8. Stack/provider selection and decision gates

Component	Recommendation	Status / why / adoption gate
Web/API	Keep Hono + TypeScript + existing Pages/Vite	Implemented; enough for SSR storefront/ops. No framework rewrite for enterprise appearance
Canonical database	Keep D1; indexed bounded queries, additive migrations	Implemented foundation/local transaction; production transaction release pending. Measure query/lock/storage limits before considering another DB
Asset storage	Private R2 + D1 version manifest/entitlement	Planned required for own paid file delivery; no paid files public bucket
Payment	Existing Duitku POP adapter	Production connection verified only; actual commerce live gate pending. No second provider solves missing customer/delivery flow
Operator identity	Cloudflare Access + MFA-capable IdP	Proposed launch-critical before ops HTTP writes; account/plan/team ownership/audience config to verify
Customer identity	First-party scoped guest session and verified recovery	Proposed; managed auth optional if customer accounts/library/org needs justify it. Customer login is not operator Access login

Component	Recommendation	Status / why / adoption gate
Abuse controls	Turnstile server verification when warranted + deployment-compatible rate limits	Required design; test Pages/BYOK support and failure path. Not financial dedup/accounting
Transactional email	Resend as preferred candidate , alternatives only if needed	Needed if email recovery/receipts promised; owned verified sender domain/DNS, budget, data processing and API delivery-webhook review before adoption [S5]
Infrastructure telemetry	Pages-compatible logs/tail plus D1 operational exceptions + independent HTTPS monitoring	Launch minimum; verify actual project log/alert/export capability, not assume all Workers features apply to advanced-mode Pages [S6]
Error tracing	Sentry optional after compatibility/privacy proof	Official SDK guidance requires nodejs_compat; current repo deliberately lacks it. No drop-in assumption; review Pages/Hono integration, payload scrubbing and compiled regression first [S7]
Public performance analytics	Cloudflare Web Analytics candidate	RUM/page analytics only, not sales truth. Beacon/CSP and account/domain/config review; business attribution facts remain internal [S10]
Reliable async	D1 durable outbox first; Queue consumer Worker when delivery timing/retries require	Conditional reliability feature with deployment/plan/budget/recovery tests; not speculative content automation
Long-running orchestration	Cloudflare Workflows later	Genuine multi-step/human approvals trigger adoption; no blanket enterprise stack requirement
Customer/growth analytics suite	Defer PostHog/large CRM/BI/CDP	Not researched/selected/provisioned; cannot outrank first canonical loop, privacy and traffic evidence

No need for Redis, Kubernetes, self-hosted PostgreSQL, event bus, full ERP, AI agents or heavy commerce framework at current volume. No prohibition on future scale: add only with measured bottleneck, capability owner, security/data processing, full landed cost, environment/testing, rollback and exit/export plan. Do not buy multiple overlapping auth/email/analytics providers.

Budget and account gates

Pricing/quotas vary. No monthly cost or SLA promised without checking actual owner plan. Build a budget worksheet from: Worker requests/CPU, D1 reads/writes/storage, R2 storage/operations, identity seats, email volume, logs/export retention, monitoring, queue/workflow consumption, payment/channel fees and support labor. Founder sets cap/alerts; unknown costs stay unknown.

Choose account ownership under TOLVEY, least-privilege CI credentials, production/test separation and documented transfer/revocation. Credentials installed only during an authorized implementation/release, never in this concept session. No uploaded-secret read needed here.

9. Production-grade controls and enterprise evolution

Production-grade is evidence, not a stack badge. Recommended launch acceptance:

- Reviewed threat model: IDOR/cross-customer access, ops origin bypass, CSRF, XSS, open redirect, forged provider event, leaked asset/token, duplicate side effects and excessive exports.
- Record/action permissions, MFA-backed ops identity, session lifecycle/recovery, immutable audit and bounded input/query/PII.
- Safe logs/errors, request/operation references, config availability, metrics and alert ownership. Audit history is not just short-retention telemetry.
- Version-pinned private assets, publication gates, consent/policy purpose/retention, consumer/support/refund procedures and legal review.
- Isolated local/test/approved sandbox; preview no production DB; release review/additive migration/fresh+upgrade compatibility, disabled-new-checkout switch and non-destructive app rollback.
- Rehearsed data/asset recovery, protected backup/export, evidence of recovery target and reconciliation of provider payments after restore. No restore strategy deleting paid facts unnoticed.
- Verified integrated customer cycle and operator failure resolution; separate authorization for production schema, keys, domain and controlled payment.

Proposed service objectives, not contracted SLA

Before launch define measured window, owner, budget and alert threshold for storefront/status availability, safe checkout-initiation errors/latency, accepted payment-to-access delay, oldest pending exception/outbox job, missing assets and support response. Public uptime alone cannot prove ability to pay/deliver. No 99.99%/instant-delivery promise without measurement/provider limits and recovery capacity.

Decide RPO/RTO from cost/customer impact and rehearse non-production. D1 Time Travel window is plan-dependent, not proof of TOLVEY recovery readiness. Restore can lose internal post-bookmark changes while provider payments survive; freeze affected writes and reconcile before reopening. Asset rollback must restore correct purchased version, not only current catalog.

Enterprise-oriented later controls

More staff/clients or contractual needs can justify actual reviewer separation, SSO/SCIM/offboarding, granular audit/export permissions, longer protected audit retention, incident/on-call process, independent security assessment, data processing/vendor register, dependency/SBOM/release provenance, load tests and split public/internal deployment. Compliance certification needs its own program/audit; this document does not imply ISO/SOC2/PCI certification. TOLVEY delegates card entry to provider; that alone is not a blanket PCI compliance determination.

10. Monitoring, finance truth and failure isolation

Signal	Internal action	Public/customer behavior
Anonymous catalog errors	Alert engineer; restore public projection	Honest temporary unavailable, no fake catalog
Ops identity/JWKS unavailable	Deny ops writes; assigned incident	Do not lock public product browsing unnecessarily
Provider unavailable/ambiguous initiation	Preserve reservation/pending + exception	Processing/support, never paid or duplicate invoice
Confirmed but delivery issue	Keep payment truth; assigned fulfillment case	Owned status shows issue and contact; retries authorized

Signal	Internal action	Public/customer behavior
Email send/bounce	Durable notification status + safe resend/recovery	Order/access stays canonical; no false product delivery claim
Growth telemetry outage	Record missing attribution; retry only allowed tracking	Purchase/access not blocked solely for analytics
DB unavailable	Fail new financial commands closed; incident/recovery	No new paid claim or entitlement from memory cache
Queue/DLQ backlog	Alert owner, inspect/replay bounded job IDs	Safe pending state; no duplicate fulfillment/payment

Financial reporting uses verified canonical payments/external evidence, not Web Analytics, Sentry, queue delivery or email opens. Gross paid ≠ settlement ≠ recognized revenue/profit. Logs/analytics sampling cannot be the only audit of critical state transitions; persist appropriate canonical evidence atomically.

Workers telemetry may automatically include URLs/query/request metadata, even if console logs are sanitized. Review invocation-log settings, export destinations, scrubbing, access/retention and costs before enabling them [S6]. Customer/contact/token/raw callback values must not be sent to external telemetry by default.

11. Indonesian business/legal launch register

Source review supports a **mandatory applicability/evidence review**, not legal clearance:

Item	Required owner action / evidence	Not claimed
Seller identity/business	Verify legal identity/form, relevant NIB/KBLI/licensing and accurate contact	TOLVEY registration/license already approved
PSE classification/registration	Assess/register applicable private electronic system through official process; official criteria include offerings/trade and paid digital delivery [S8]	Public UI implies PSE Lingkup Publik, or domain gives exemption
PMSE/consumer contracts	Review applicable PP80/2019 and current implementing rules; disclosure, contract/receipt, complaints, delivery/refund commitments [S9]	Exhaustive legal analysis of all current obligations
PDP	Identify controller/processors, purpose/legal basis, minimum collection/retention/access, rights/incident process and cross-border/vendor review [S11]	Generic cookie banner or vendor badge proves PDP compliance
Tax/payment/payout	Professional review of actual business/transaction obligations; provider merchant eligibility/fees/settlement	Authenticated provider connection proves business/legal acceptance
IP/license/product claims	Own/permissioned assets, permitted template/platform licenses, honest limits	Money Kit/financial outcomes guaranteed
Marketing	Lawful claims, channel/ad policy, consent/opt-out and budgets	Internal growth dashboard permits every platform or spend

Registration status, entity owner and legal decisions are sensitive internal records; public pages disclose only verified necessary details. Do not publish registration numbers/badges that have not been issued. Record owner, source, review date, applicability conclusion/evidence and unresolved items. This is not legal advice.

12. Current gaps and build sequence

Current code has read-only foundation UI/catalog, local transaction/POP contract and protected production connection check. It has **no** ops console/Access integration, customer ownership checkout, R2 entitlements, email recovery, channel/demand console, outbound registry, outbox/queue/workflow, advanced telemetry or legal-readiness evidence. Documentation commit does not redeploy code.

Priority	Slice / deliverable	Gate
P0	Public/internal policy contract, operator identity/offboarding, audited draft/review/publication, one real product page	Ops denied without verified identity, missing package blocked, drafts hidden, active page safe; payment remains closed
P0	Customer session/contact/policy + owned checkout/status	Principal-scoped idempotency, other-customer denial, CSRF/abuse/expiry/recovery; server money
P0 provider	Separate Phase 3 actual deployed sandbox initiation/payment/callback/status/reconcile	Existing live gate still required; no stub/production-auth substitution or env spoof
P0	Private version delivery + operator order/exception/support view	Payment-gated grant, pinned bytes, unpaid/other recipient denied, paid failure recoverable
P0 release	Business/legal register + domain/identity, recovery/alerts and authorized Phase 7 release	Evidence-based owner/legal/security review, approved migrations/keys/DNS/payment, real controlled delivery
P1	Distribution/demand desk + approved destinations/manual external intake	Policy/version/source/evidence unique; open redirect and data leak denied; no fake sale
Conditional	Email/outbox/drain/queue and fuller monitoring	Adopt when promised timing/recovery needs it; tests for duplicate/timeout/DLQ/replay
Later	Service milestones/customer library, role separation, split deployments/Workflows/analytics automation	Real scope/team/load/economic justification, reviewed boundaries

Preserve phases 0–8; these are slices/dependencies, not new A/B/C phases. An enterprise-looking dashboard is not a prerequisite to public launch; identity/permissions and smallest useful operational controls are. Independent product QA/content/read-only page work can proceed while provider gate blocked under separate request. No payment/deploy/DNS/resource change authorized by this conceptual request.

13. Acceptance tests for layer separation (target, not executed)

1. Anonymous can see published product/help, cannot see draft/ops/order/assets.
2. Customer A cannot enumerate/read/initiate/download/recover Customer B, including replaying another customer's idempotency key.

3. Missing/forged/expired/wrong-audience Access identity denies ops on custom and default/immutable/preview origins; disabled principal denied despite otherwise valid token.
4. Growth operator cannot read payment/customer contact or publish unapproved offer; support cannot export unrestricted finance or create arbitrary entitlement.
5. Cookie mutation fails CSRF/origin tests; machine callback remains reachable without human challenge but rejects invalid signature/money/reference/state.
6. Outbound destination ID never accepts arbitrary URL; disabled listing fails; no order/token/PII in external URL/referrer/telemetry.
7. Publish requires valid real package/terms and active parents; unpublish stops new checkout but preserves prior purchased version.
8. Duplicate callback/job/import produces one canonical transition/grant; at-least-once delivery never means extra sale.
9. Provider timeout leaves ambiguity visible; retry cannot delete RESERVED/create new invoice; late paid after expiry routed to reviewed exception.
10. Missing object/email bounce/JWKS/analytics/queue outage produces correct isolated failure and safe support, not fabricated payment/delivery.
11. Public cache cannot leak private response/credentials; public product changes do not rewrite purchase snapshots.
12. Fresh/upgrade migrations and compiled Worker/browser behavior pass; app rollback/data recovery reconciles external paid events and correct version assets.

No new acceptance test or production penetration test is claimed passed by this design. Last full runtime suite: inherited 237; this document's validation is link/content/file integrity and source/config unchanged, reported in delivery.

14. Official-source register — reviewed 2026-10-01

- **S1 — Access JWT verification:** <https://developers.cloudflare.com/cloudflare-one/access-controls/applications/http-apps/authorization-cookie/validating-json/> — Worker must validate signature/issuer/audience; JWKS rotation. No Access resource configured.
- **S2 — Pages bindings:** <https://developers.cloudflare.com/pages/functions/bindings/> — D1/R2/service bindings and queue producers; Pages cannot consume queue events, separate Worker required. Actual project capability/config must be tested.
- **S3 — Queue delivery:** <https://developers.cloudflare.com/queues/reference/delivery-guarantees/> — at least once and consumer dedup required. No queue created.
- **S4 — Durable workflows:** <https://developers.cloudflare.com/workflows/> — durable steps/retry/wait events; conditional future choice.
- **S5 — Email sender domains:** <https://resend.com/docs/dashboard/domains/introduction> — domain ownership/verification, subdomain reputation segmentation; not mailbox hosting/account approval or guaranteed inbox delivery.
- **S6 — Workers Logs:** <https://developers.cloudflare.com/workers/observability/logs/workers-logs/> — logs/sampling/retention, invocation URL metadata, export; verify Pages-specific capability instead of copying Workers-only config blindly.
- **S7 — Sentry Cloudflare:** <https://docs.sentry.io/platforms/javascript/guides/cloudflare/> — official SDK integration guidance, nodejs_compat and Pages/Hono distinctions; privacy/data collection review needed. Optional, not installed.
- **S8 — Komdigi PSE criteria:** <https://pse.komdigi.go.id/panduan/kriteria-pendaftaran-pse-lingkup-privat> — rendered content confirms offering/trade and paid digital delivery criteria and obligation when criteria met. Not a registration-status lookup or legal determination for TOLVEY.

- **S9 — PMSE:** <https://jdih.kemendag.go.id/peraturan/peraturan-pemerintah-nomor-80-tahun-2019-tentang-perdagangan-melalui-sistem-elektronik> — rendered official record: PP80/2019 PMSE, status Berlaku; full legal-text/current implementing-rule analysis not performed.
- **S10 — Web performance analytics:** <https://developers.cloudflare.com/web-analytics/about/> — privacy-first RUM/page performance, not canonical sales metrics.
- **S11 — PDP official reference located:** <https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022> — official search metadata identified UU27/2022; full text/applicability not analyzed in this session.

PSE and JDIH initial plain crawl returned page shell; JS-rendered retry retrieved substantive content. Other technical references retrieved directly. Research is not vendor/account/legal approval. Related full-cycle specification: docs/19; gates: docs/15; business strategy: docs/39/34; ops: docs/10; metrics: docs/27.